

Enci/ VENTAS

Informe de QA y Validación

Evidencia funcional, técnica y de seguridad para UAT / Go-Live controlado

Versión 1.0

Proyecto Enci / Enci Ventas

Aplicación de Automatización de Fuerza de Ventas

Julio 2026

QA Validacion tecnica	UAT Validacion cliente	SEGURIDAD Casos de abuso	PLM UTEM Entrega tecnica
--------------------------	---------------------------	-----------------------------	-----------------------------

Responsable de la documentación

Documento elaborado por el Grupo PLM de la Universidad Tecnológica Metropolitana (UTEM). Líder: Joshua Flores. Integrantes: Falon Berrios, Caroline Palacios y Eliseo Poblete.

Naturaleza del informe

Este informe consolida el resultado esperado de QA para el MVP web avanzado Enci/ Ventas y define el marco de validación para UAT y go-live controlado. El cierre de Development no equivale a salida productiva automática: la salida productiva depende de ambiente, credenciales, dominios, usuarios reales y aprobación del cliente.

Tabla de Contenidos

1. Introducción
2. Estado ejecutivo de QA
3. Alcance de validación
4. Evidencia técnica versionada
5. Validaciones técnicas ejecutables
6. Matriz UAT por rol
7. Smoke test de despliegue
8. Casos de abuso y seguridad
9. Severidad de defectos
10. Criterio de salida UAT
11. Riesgos QA y restricciones
12. Evidencia mínima para cierre
13. Acta de decisión QA

1. Introducción

El presente informe establece la línea base de aseguramiento de calidad para la entrega del sistema Enci/ Ventas. El objetivo es ordenar la evidencia técnica, funcional y de seguridad que permite declarar el MVP web avanzado como cerrado para Development y preparado para validación UAT / go-live controlado.

La validación se enfoca en comprobar que la solución opere de forma consistente en sus flujos críticos: autenticación con Firebase, autorización backend por rol, CRM de clientes, usuarios y roles, importación CSV, interacciones comerciales, oportunidades, propuestas, dashboards, readiness, Swagger controlado, controles defensivos, IA RAG parcial y aplicación Flutter nativa parcialmente realizada como componente adicional externo al monorepo.

1.1 Principios de validación

- La autorización definitiva debe vivir en backend; la interfaz solo organiza la experiencia visual.
- El vendedor debe operar únicamente sus datos propios y no acceder a registros de otros vendedores.
- Las operaciones sensibles deben retornar error controlado ante ausencia de token, rol insuficiente o propiedad inválida.
- Los defectos UAT deben diferenciarse de mejoras, cambios de alcance, exclusiones y limitaciones parciales ya documentadas.
- Ninguna validación debe exigir credenciales reales dentro del repositorio ni exposición de secretos en frontend.

2. Estado ejecutivo de QA

Conclusión ejecutiva

El MVP web avanzado se considera cerrado para Development y preparado para UAT/go-live controlado. La salida productiva queda condicionada a validación con usuarios reales, ambiente final, dominios autorizados, credenciales vigentes, revisión de readiness y aceptación formal del cliente.

Ámbito	Estado QA	Observación de cierre
MVP web comercial	Aprobado para Development	Flujos críticos documentados; UAT valida operación en ambiente objetivo.
Backend FastAPI	Aprobado con validación técnica	Endpoints protegidos, roles, payloads, readiness y seguridad básica.
Frontend React/Vite	Aprobado con validación visual pendiente UAT	Navegación, rutas, dashboard y vistas comerciales sujetas a ambiente final.
Firestore/Firebase	Aprobado con dependencia de credenciales	Validación real depende del proyecto Firebase y dominios autorizados.
IA RAG parcial	Aceptada como parcial	Se valida implementación actual; no incluye tuning, entrenamiento ni cambio de proveedor.
App Flutter parcial	Aceptada como parcial externa	No se evalúa por ausencia en GitHub; se valida según evidencia entregada y acuerdo con Max.
Go-live	Condicionado	Requiere readiness, smoke test, usuarios reales y decisión de salida.

3. Alcance de validación

El alcance de QA se limita a las capacidades comprometidas para el MVP web avanzado y a la documentación explícita de componentes parciales. No se considera falla de QA la ausencia de funcionalidades excluidas, la falta de publicación en tiendas móviles, la inexistencia de E2E completo por login real pendiente, ni la necesidad de definiciones comerciales que dependen del cliente.

Código	Área	Validación esperada
QA-01	Autenticación	Login Google, token Firebase Bearer, sincronización de usuario y bloqueo por estado inactivo.
QA-02	Roles	Jerarquía admin, supervisor y vendedor aplicada desde backend.
QA-03	Cientes CRM	Crear, listar, buscar, filtrar, editar y baja lógica con propiedad por vendedor.
QA-04	CSV	Carga masiva admin, validación UTF-8, columnas, tamaño, duplicados y fórmulas.
QA-05	Flujo comercial	Interacciones, oportunidades, propuestas, estados y cálculo server-side.
QA-06	Dashboards	Métricas propias y consolidadas según rol.
QA-07	Readiness	Verificación de ambiente, credenciales, CORS y claves requeridas.
QA-08	Seguridad	403, 404, 422, límites, CORS, payload y abuso por manipulación de IDs.
QA-09	RAG parcial	Chat, fuentes, documentos, rate limit, API key backend y respuesta sin contexto.
QA-10	Flutter parcial	Validación por evidencia externa: APK/UI/login/navegación; no cobertura total backend.

4. Evidencia técnica versionada

La validación técnica se apoya en archivos y documentos de proyecto versionados. Estos respaldos sirven para repetir verificaciones, auditar cambios y demostrar que las pruebas se ejecutan sobre criterios definidos, no sobre apreciaciones informales.

Evidencia	Uso en QA	Estado esperado
README.md	Stack, alcance MVP, endpoints, variables, instalación local y checklist funcional.	Referencia base de entrega.
docs/qa/epic-03-auditoria.md	Auditoría QA y seguridad de autenticación, CRM, CSV, flujo comercial y parches.	Histórico técnico de cierre EPIC 3.
docs/qa/epic-04-hardening.md	Hardening, dashboards, rutas 403/404, sesión expirada y navegación por rol.	Cerrado para Development.
docs/qa/epic-05-uat-go-live.md	Readiness, matriz UAT, smoke test, severidad y rollback.	Base de UAT/go-live.
Backend/tests/test_readiness.py	Validación automatizada de readiness para Firebase, credenciales, CORS y DeepSeek.	Debe mantenerse en verde.
Backend/tests/*	Cobertura de permisos, seguridad, CSV, flujo comercial y modelos.	Debe ejecutarse antes de entrega.
frontend/package.json	Scripts lint, build, test y dependencias frontend.	Build y lint sin errores bloqueantes.
firestore.rules	Regla deny-all para evitar acceso directo desde cliente.	Debe permanecer cerrada.

5. Validaciones técnicas ejecutables

La siguiente batería de comandos debe ejecutarse antes de una entrega UAT o productiva. El resultado debe registrarse con fecha, hora, ambiente, commit o versión, responsable y evidencia de salida.

5.1 Frontend web

```
cd frontend
npm audit --audit-level=moderate
npm run lint
npm run build
```

Resultado esperado: auditoría sin vulnerabilidades moderadas o superiores como objetivo de cierre, ESLint sin errores bloqueantes y build Vite generado correctamente en dist.

5.2 Backend API

```
cd Backend
uv run pytest
python -m compileall app tests
```

Resultado esperado: suite backend en verde, sin errores de sintaxis y sin fallas en pruebas de permisos, readiness, seguridad, flujo comercial ni CSV. El último registro operativo conocido indica 67 pruebas backend aprobadas; el número final debe confirmarse al cierre del Hito 5.

5.3 Readiness de ambiente

```
curl https://api.example.com/health
curl https://api.example.com/readiness
```

Resultado esperado: /health retorna status ok y /readiness retorna status ready. En UAT/staging/production, el reporte no debe aceptar CORS con localhost o 127.0.0.1 ni placeholders en Firebase.

Validación	Condición de aprobación	Falla bloqueante
Lint frontend	npm run lint sin errores.	Errores que impidan build o afecten rutas críticas.
Build frontend	npm run build genera dist.	Compilación rota o variables VITE faltantes.
Pytest backend	Suite completa en verde.	Cualquier falla S1/S2 o regresión de seguridad.
Compileall	Sin errores de sintaxis.	Módulos backend no importables.
Readiness	status ready con checks ok.	Credenciales, CORS, Firebase o DeepSeek mal configurados.

6. Matriz UAT por rol

La UAT debe ejecutarse con usuarios reales o cuentas de prueba autorizadas por rol. El foco es validar la experiencia completa desde navegador, no solo llamadas API. Los resultados deben quedar marcados como Aprobado, Aprobado con observación, Fallido o No ejecutado.

Caso	Rol	Pasos mínimos	Resultado esperado
Login Google real	Todos	Abrir /login, seleccionar cuenta autorizada.	Sesión iniciada y usuario sincronizado en Firestore.
Dashboard vendedor	Vendedor	Ingresar a dashboard con datos propios.	Métricas personales visibles sin error API.
CRM clientes propios	Vendedor	Abrir clientes, buscar, filtrar y revisar detalle.	Solo clientes asignados al uid del vendedor.
Crear cliente	Vendedor/Admin	Registrar cliente válido y guardar.	Cliente creado con vendedor/owner correcto.
Interacción comercial	Vendedor	Registrar llamada, visita, correo o reunión.	Interacción vinculada a cliente visible.
Oportunidad	Vendedor	Crear oportunidad y cambiar etapa.	Pipeline actualizado sin permitir propiedad ajena.
Propuesta	Vendedor	Crear propuesta asociada a oportunidad.	Monto descuento y total calculados server-side.
Dashboard supervisor	Supervisor/Admin	Abrir métricas agregadas.	Consolidado de equipo visible.
Usuarios y roles	Admin	Cambiar rol/estado de usuario.	Cambio persistido y auditado.

Caso	Rol	Pasos mínimos	Resultado esperado
Importación CSV	Admin	Subir CSV válido e inválido.	Válido importa; inválido rechaza sin escritura parcial.
Ruta sin permiso	Vendedor	Intentar ruta de supervisor/admin.	Pantalla 403 o respuesta backend 403.

7. Smoke test de despliegue

El smoke test se ejecuta después de cada despliegue UAT o productivo. Su objetivo es confirmar que el ambiente mínimo está operativo antes de habilitar pruebas funcionales completas.

```
python tools/smoke_crm_web.py --env uat --api-base-url https://api.example.com --web-url https://crm.example.com
```

Si la herramienta no está disponible en el ambiente final, el smoke test debe ejecutarse manualmente con los mismos criterios mínimos: abrir web, iniciar sesión, consultar /me, listar clientes según rol, abrir dashboard y verificar readiness.

Paso	Verificación	Resultado esperado
1	Abrir frontend web.	Pantalla de login visible.
2	Login Google real.	Token Firebase obtenido y sesión válida.
3	GET /me.	Usuario retorna uid, email, rol y activo.
4	GET /clientes.	Lista filtrada según rol.
5	Dashboard.	Métricas cargan sin error API.
6	GET /readiness.	status ready con checks ok.
7	Error 403 controlado.	Ruta sin permiso no renderiza datos protegidos.

8. Casos de abuso y seguridad

Los casos de abuso validan que el sistema falle de manera segura cuando un usuario intenta manipular IDs, usar tokens inválidos, alterar roles, forzar payloads no permitidos o acceder a información ajena. Estos casos son prioritarios porque protegen la integridad comercial del CRM.

Caso	Vector	Resultado esperado	Severidad si falla
Vendedor accede cliente ajeno	GET /clientes/{id} manipulado.	403 sin datos del cliente.	S1
Vendedor modifica cliente ajeno	PATCH cliente ajeno.	403 o 404 controlado.	S1
Interacción en cliente ajeno	POST /interacciones con clienteld externo.	403.	S1
Propuesta con oportunidad ajena	POST /propuestas con oportunidadId externo.	400/403.	S1
Usuario inactivo con token válido	Token Firebase vigente de usuario desactivado.	403 y bloqueo de sesión.	S1
Payload con campos extra	Campos sensibles no definidos.	422 por extra forbid.	S2
CSV con fórmula	Campo iniciado en =, +, - o @.	Rechazo de fila/archivo.	S2
CSV duplicado	Email repetido interno o existente.	Rechazo sin importación parcial.	S2
Docs en producción	Abrir /docs u /openapi.json.	404/no expuesto.	S2
CORS inseguro en UAT	localhost en CORS_ORIGINS.	readiness not_ready.	S2

9. Severidad de defectos

Toda observación UAT debe clasificarse por severidad. La severidad define si el sistema puede salir, si requiere aprobación formal, o si debe bloquear el despliegue hasta corregir.

Severidad	Definición	Ejemplos	Decisión de salida
S1 Bloqueante	Impide login, uso del sistema, acceso crítico o causa pérdida/corrupción de datos.	Login roto; vendedor ve datos ajenos; escritura corrupta.	No salir.
S2 Alta	Impide flujo comercial crítico con workaround limitado o afecta seguridad relevante.	Propuestas no guardan; CSV no valida; readiness not_ready.	No salir sin aprobación formal.
S3 Media	Afecta productividad, pero existe workaround claro.	Filtro visual incorrecto; mensaje poco claro; demora tolerable.	Puede salir con plan y responsable.
S4 Baja	Texto, documentación, ajuste visual menor o mejora no crítica.	Ortografía, margen visual, etiqueta no bloqueante.	Puede salir.

10. Criterio de salida UAT

Regla de salida

No debe existir S1 abierto. Todo S2 requiere corrección o aprobación formal del cliente con riesgo aceptado. Los S3 pueden salir si tienen plan de corrección, responsable y fecha comprometida. Los S4 no bloquean salida.

Condición	Exigencia mínima
Disponibilidad	/health operativo y frontend accesible.
Configuración	/readiness en ready para ambiente objetivo.
Autenticación	Login Google real validado con al menos un usuario autorizado.
Roles	Vendedor, supervisor y admin validados en flujos críticos.
Datos	Clientes, interacciones, oportunidades y propuestas sin errores de propiedad.
Seguridad	Casos de abuso críticos bloqueados.
RAG parcial	Consulta básica funcionando o limitación expresamente aceptada.
Flutter parcial	Estado entregado validado según evidencia externa acordada con Max.
Defectos	Matriz de defectos cerrada o aceptada según severidad.

11. Riesgos QA y restricciones

Los siguientes riesgos no invalidan el cierre de Development si quedan registrados y aceptados. Deben revisarse antes de producción real o tratarse como Fase 2 cuando excedan el alcance comprometido.

Riesgo	Impacto	Tratamiento
UAT autenticado depende de usuarios reales.	No permite validar login completo sin cuentas autorizadas.	Coordinar cuentas de prueba con cliente.
Validación visual depende de ambiente desplegado.	Build local no reemplaza revisión UAT.	Ejecutar checklist visual post deploy.
E2E completo no automatizado.	Riesgo de regresiones visuales/manuales.	Planificar Playwright o equivalente en Fase 2.
Firestore con filtros en memoria.	Aceptable para MVP, no ideal para alto volumen.	Migrar a queries/indexes antes de escalamiento real.

Riesgo	Impacto	Tratamiento
IA RAG parcial depende de proveedor externo.	Calidad y disponibilidad sujetas a DeepSeek/API key.	No prometer SLA externo ni tuning adicional.
Flutter parcial externo al repo.	Trazabilidad no se prueba desde monorepo.	Validar por APK, capturas, demo y acuerdo con Max.

12. Evidencia mínima para cierre

Cada ejecución de QA debe dejar una huella suficiente para repetir, auditar y explicar el resultado. La evidencia debe adjuntarse al acta de cierre o quedar referenciada en el repositorio documental del proyecto.

Elemento	Detalle requerido
Comando ejecutado	Comando exacto, ruta de ejecución y parámetros utilizados.
Fecha y hora	Marca temporal de ejecución y responsable.
Ambiente	Local, UAT, staging o producción; URL frontend y API.
Commit/versión	SHA, rama o versión del build validado.
Resultado	Passed, failed, blocked, not executed o approved with observation.
Capturas	Obligatorias para UAT visual, 403, 404, dashboard y errores relevantes.
Defectos abiertos	ID, severidad, responsable, workaround y decisión de salida.
Decisión final	Salir, salir condicionado, bloquear salida o reintentar validación.

13. Acta de decisión QA

La decisión final de QA debe registrarse antes del cierre de UAT. Esta decisión no reemplaza la aceptación comercial, pero deja constancia del estado técnico validado.

Campo	Valor a registrar
Proyecto	Enci/ Ventas
Documento	DOC-14 - Informe de QA y Validación
Responsable técnico	Grupo PLM UTEM
Líder	Joshua Flores
Integrantes	Falon Berrios, Caroline Palacios y Eliseo Poblete
Ambiente validado	Local / UAT / Producción controlada
Resultado QA	Aprobado / Aprobado condicionado / Bloqueado
S1 abiertos	Debe ser cero para salida.
S2 abiertos	Requieren aprobación formal si no se corrigen.
Observaciones finales	Registrar pendientes UAT, limitaciones parciales y próximos pasos.

Cierre del informe

El sistema queda apto para validación UAT/go-live controlado si las pruebas técnicas base se encuentran en verde, los casos de abuso críticos responden como se espera, readiness confirma ambiente objetivo y el cliente acepta formalmente cualquier observación residual no bloqueante.